ISACA
Omaha Chapter

Audits, Assessments, & Consulting:
Navigating the Frontlines of Cybersecurity and Compliance

September 2025

Who am I?

Identity Paradox

How do you know
(I'm not a deep-fake)?



>whoami

Ron Woerner

- Hacker
- Cybersecurity Consultant / Trusted Advisor
- Professor, Bellevue University
- 25+ years experience in IT / Security
- Blogger, writer, and podcaster

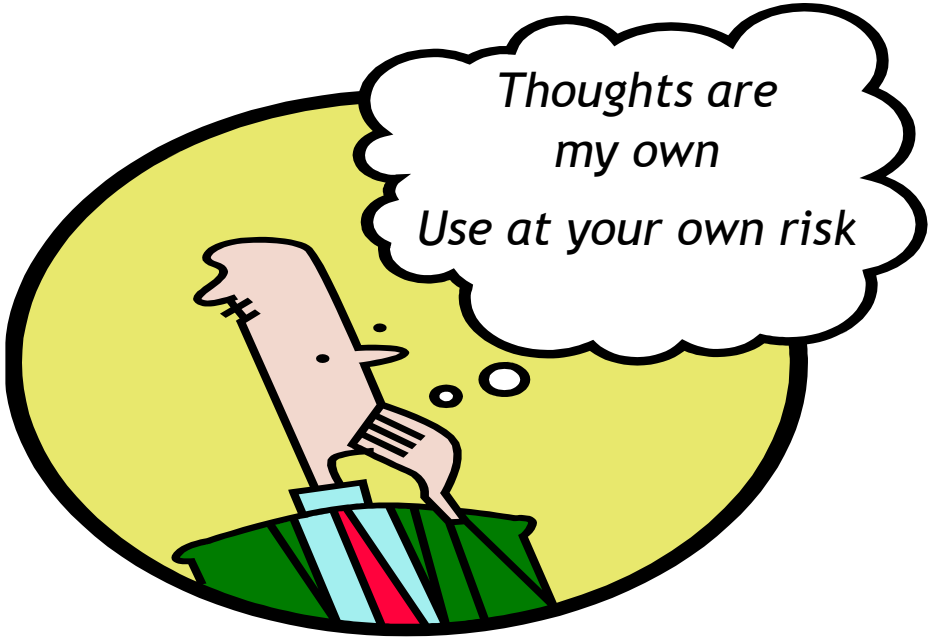


TEDx Omaha, 2019, Hackers Wanted

LinkedIn: https://www.linkedin.com/in/ronwoerner/

Websites & Social Media: https://linktr.ee/cyberron

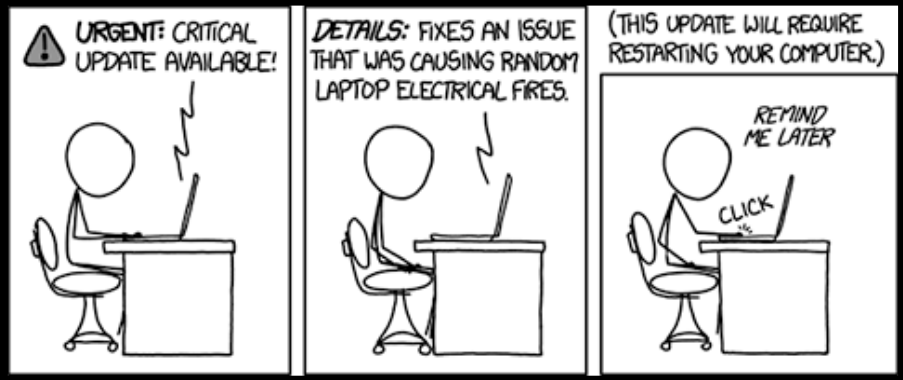
FORRESTER®



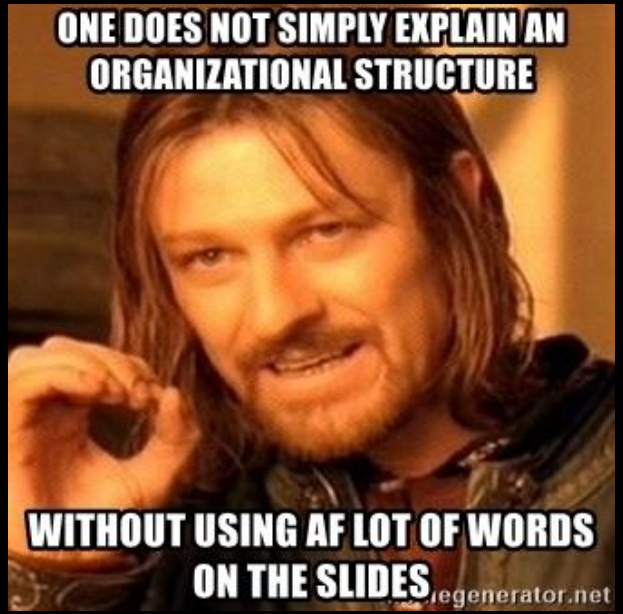


Please Ask Questions

PARENTS STRONGLY CAUTIONED
PG-13
SOME THEMATIC ELEMENTS, AND LANGUAGE
Some Material May Be Inappropriate for Children Under 13



What the $%$# are we doing here?



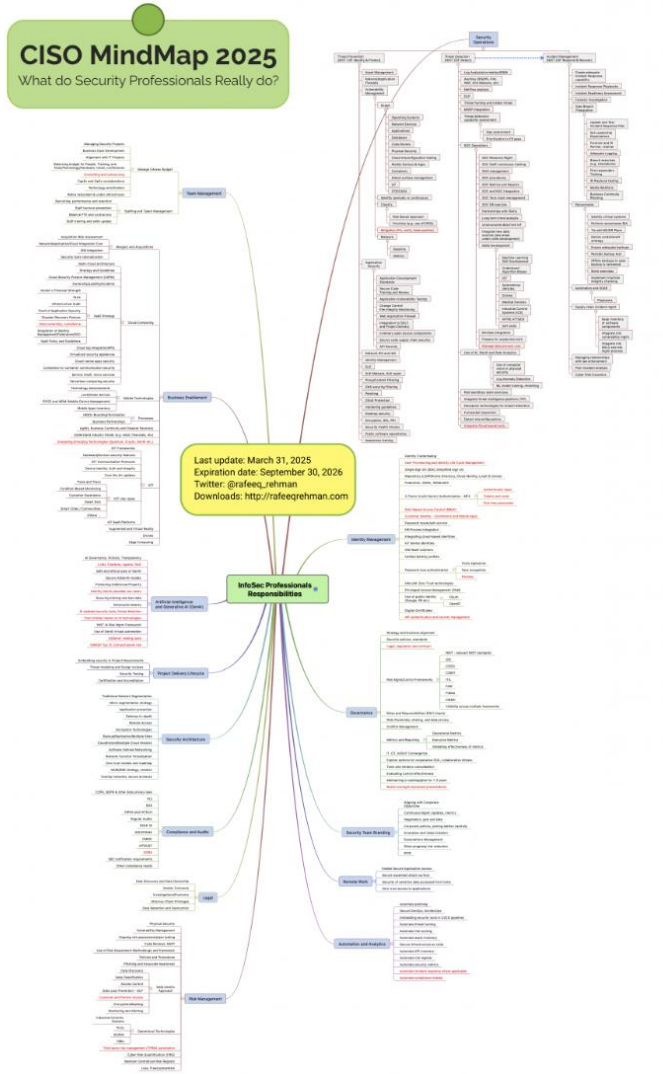


Learning objectives:

1. **Recognize the Consultant's Role** – Gain insights into the responsibilities, challenges, and opportunities consultants face when advising organizations.
2. **Understand the Audit & Assessment Lifecycle** – Learn how consultants plan, scope, execute, and report on audits and assessments across compliance, privacy, and security domains.
3. **Develop Essential Skills for Success** – Explore the mix of technical expertise, business acumen, communication, and relationship-building needed to thrive as a consultant.
4. **Bridge Frameworks to Real-World Practice** – See how standards, regulations, and risk frameworks are applied in practice to improve governance and strengthen organizational resilience.

Exploring the strategic and practical dimensions of AI in cybersecurity.

LIFE OF A CYBERSECURITY CONSULTANT



Focus Areas for 2025-26

1. It is time for securing GenAI
2. Consolidate and rationalize security tools
3. Identify and manage security debt
4. Ransomware and Cyber resilience
5. Create meaningful metrics
6. Improve Cyber Hygiene

© Copyright 2012-2025 - Rafeeq Rehman

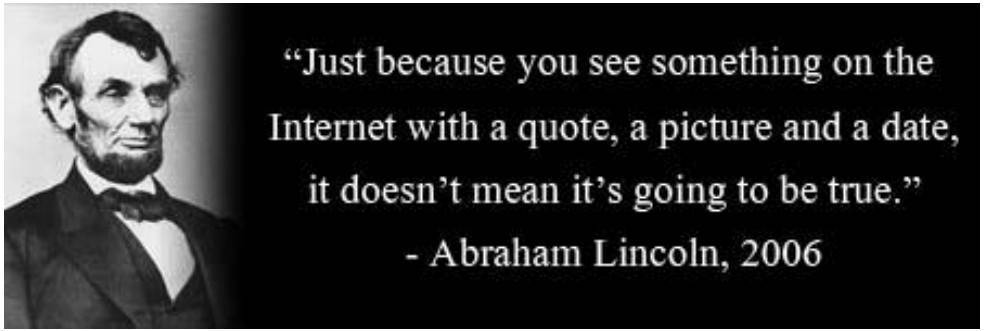
Source: https://rafeeqrehman.com/2025/03/30/ciso-mindmap-2025-what-do-infosec-professionals-really-do/

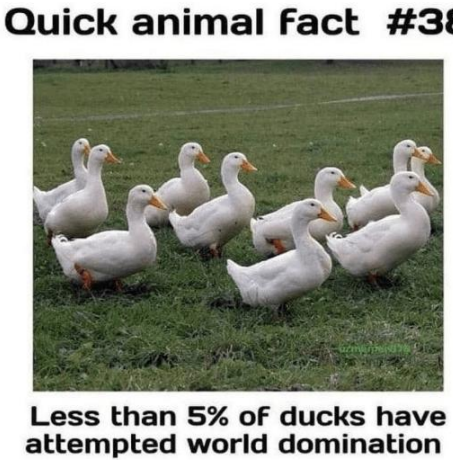
Cybersecurity (& AI) Core Principle

Trust, AND *Verify*

"*Never trust a single data point*."

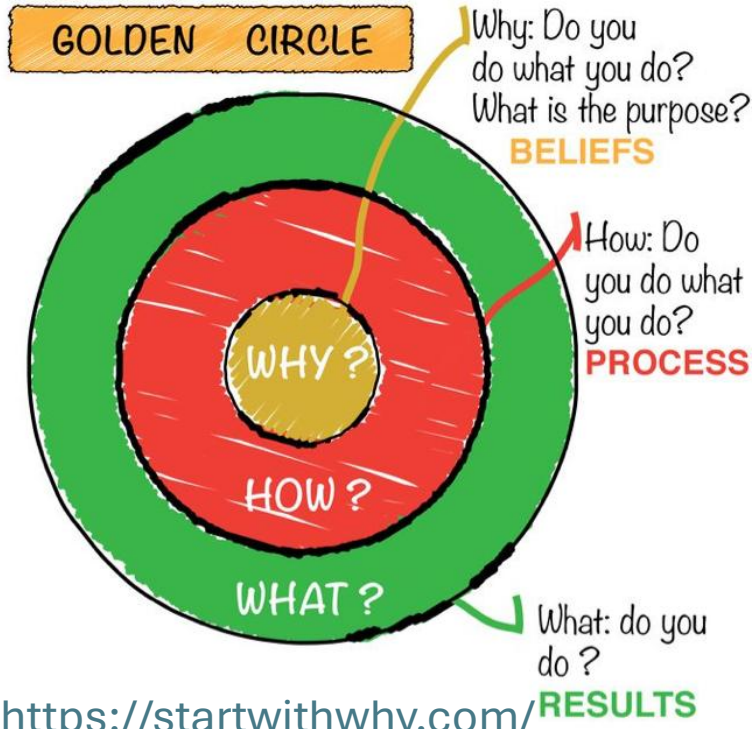
from my life as a military intelligence officer





Root Cause – Start with "Why"

What problem are you solving?



https://startwithwhy.com/

To AI or not to AI, That is the Question…

Philosophical Reflection



How/when/where/why do you use AI?

To AI or not to AI, That is the Question…

Philosophical Reflection

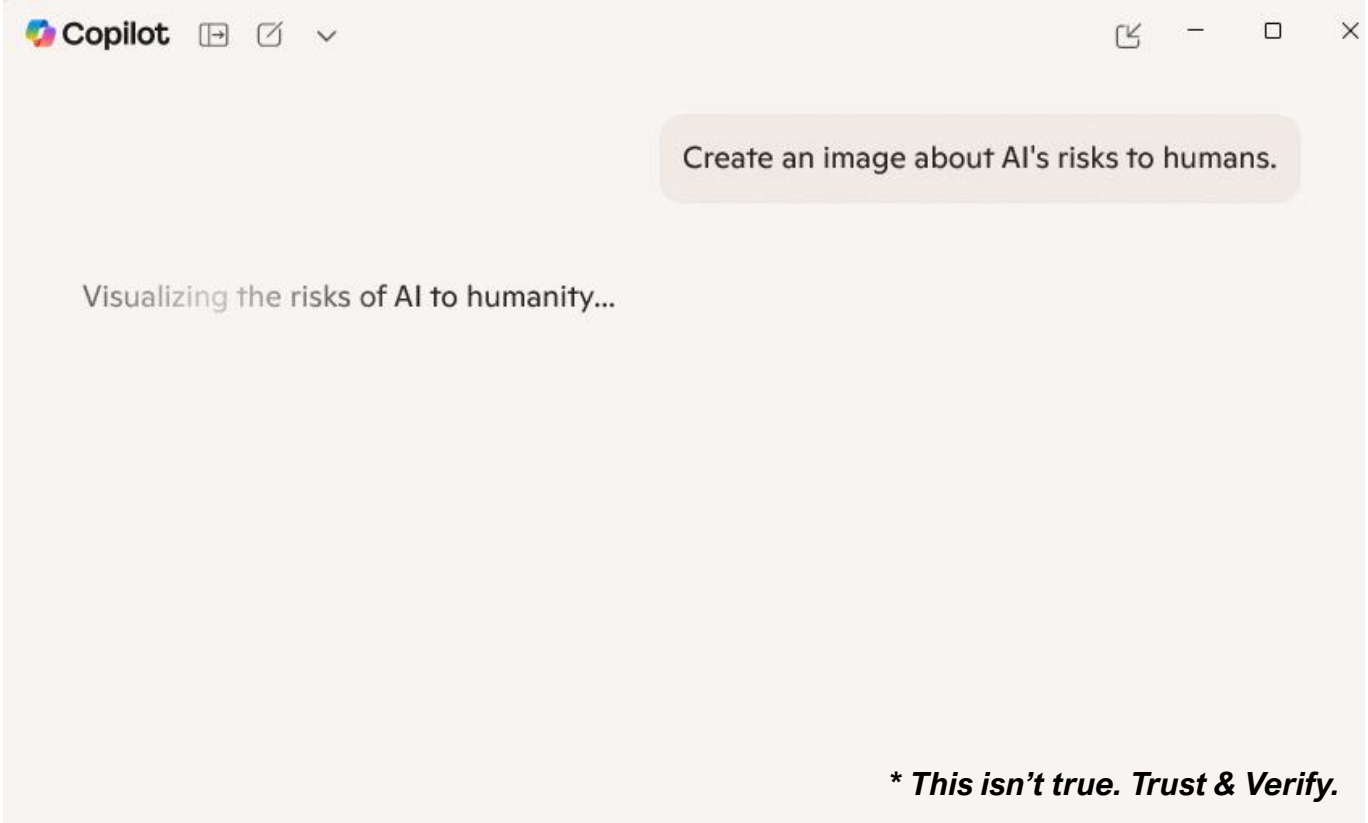
NIST AI Risk Management Framework

AI Risks & Trustworthiness

1. Valid and Reliable
2. Safe
3. Secure and Resilient
4. Accountable and Transparent
5. Explainable and Interpretable
6. Privacy-Enhanced
7. Fair – with Harmful Bias Managed

- How do you know **what's "true"** and **verify results**?
  - How do you define and measure "**trust**"?
- Explore ethical dilemmas
  - What **bias** may be introduced?
  - **Over-reliance on machines***
- **Balancing automation** with human involvement
- Embracing **continuous learning** and interdisciplinary fluency

AI Human Risks



**** This isn't true. Trust & Verify.***

AI Human Risks



FINANCIAL TIMES

Accenture to 'exit' staff who cannot be retrained for age of AI

Group details $865mn restructuring programme and outlook reflecting sluggish corporate demand for consulting projects



The job cuts allowed Accenture to say it would continue to expand operating profit margins at its historic annual rate of at least 10 basis points in the next fiscal year © REUTERS

https://www.ft.com/content/a74f8564-ed5a-42e9-8fb3-d2bddb2b8675

What You Can (Should) Do

Only You Can Protect Yourself and Others

- Embrace Continuous Learning
- Secure by Design / Build Security In
- Adversarial Techniques
- Threat Modeling
- Zero Trust



Building Skills: Experiment

- *Ethically & safely*.
  Set up a home lab.
- Learn through doing
- Ask questions
- Sun Tzu's The Art of War:
  "*Know the enemy and know yourself; in a hundred battles you will never be in peril.*“



Mastering Fundamentals

Cybersecurity:

- Computer Science, Math, Economics, Marketing, Psychology
- GRC
- Design Principles / Zero Trust
- Threat Modeling

AI:

- SDLC / Coding Best Practices
- Core Algorithms: Decision trees, neural networks, clustering
- Prompt Engineering

Understanding the "why" behind the model helps you spot challenges and design more resilient systems.

AI Terms & Definitions

Reference*:
https://iapp.org/resources/article/key-terms-for-ai-governance/

LLM (Large Language Model): A type of deep learning model trained on massive text datasets to understand and generate human-like language.

- **Core Use:** Text generation, summarization, translation, coding assistance
- **Examples:** GPT-4, Claude, Gemini, LLaMA

NLP (Natural Language Processing): An AI subfield that enables machines to understand, interpret, and generate human language.

- **Core Use:** Text classification, entity recognition, translation, summarization
- **Examples:** Siri, Alexa, ChatGPT, Google Translate

Multimodal Models: AI systems capable of processing and integrating information from multiple types of data — or "modalities" — such as text, images, audio, video, and sensor input.

GenAI (Generative AI): Models that create new content — text, images, audio, code — based on learned patterns from training data.

Agentic AI: Autonomous systems that can set goals, plan, and execute tasks with minimal human intervention. These systems use LLMs as a "brain" and orchestrate multiple agents to complete complex workflows.

Prompt: A question, instruction, or input given to an AI model to guide its response.

Vibe Coding: an emerging development style where programmers use natural language to guide AI tools in generating code.

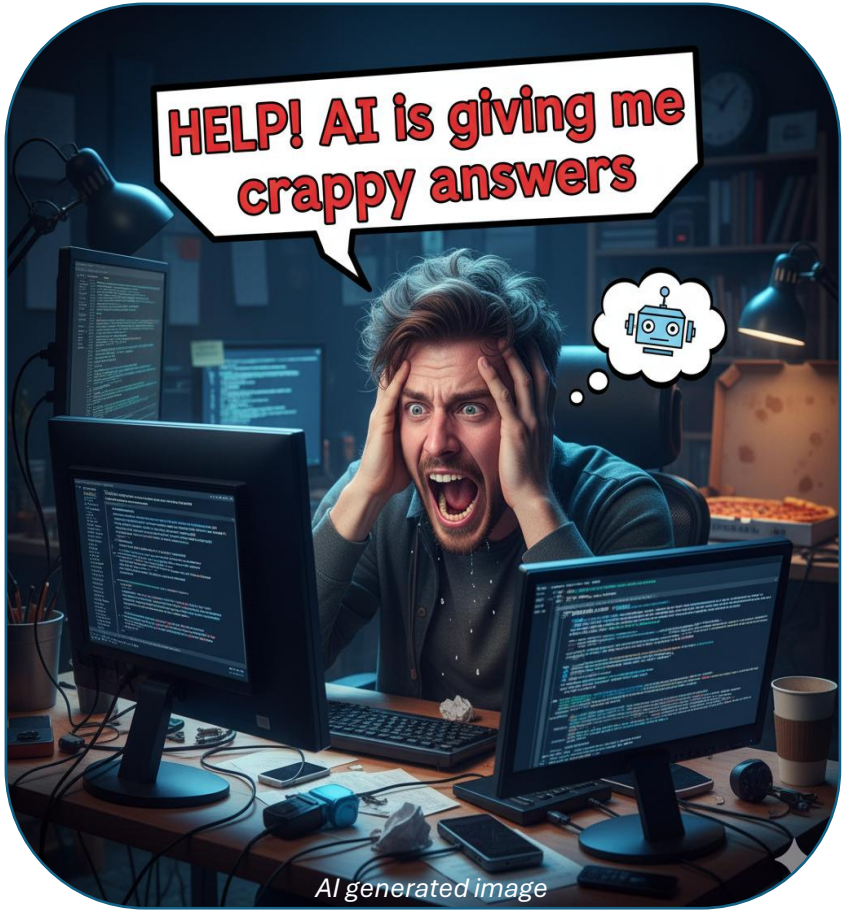
- **Core Use:** Fast prototyping, solo app development, creative coding
- **Tools:** Replit, Cursor, GitHub Copilot

AI Conversations: Prompting Fundamentals

Asking good questions

- **Clarity & Conciseness:** Always key.
- **Context is Key**: Emphasize why context matters.
- **Activity:** Vague vs. specific prompts.
- **Specifying Format:** How you want the output (list, email, table, etc.).
- **Persona & Tone:** Telling Gemini who it is and how to respond.
- **Constraints:** What to avoid or include (e.g., "Keep it under 100 words," "Do not include personal names").
- **Iterate & Refine:** AI is a dialogue; refine prompts for better results.

What are your prompting tips?



1. Prompt fundamentals
2. Ask it:
   - “Be direct, objective, expose blind spots, challenge assumptions”
   - Play “Devil’s Advocate.” Critique ideas from multiple personas & angles
   - For credible citations and flag weak evidence - Include source links
   - Show its work / “thought process”
   - For clarity and conciseness
3. Start over. Try a different tact

Core AI Competencies for Cyber Professionals

Technical Skills to Cultivate:

AI Fundamentals:
Machine learning, deep learning, NLP, prompt engineering, and model evaluation

AI-Specific Threats:
Deepfakes, automated phishing, model inversion, data poisoning

Secure Development Practices:
Threat modeling, secure coding, and adversarial robustness

Data Handling & Privacy:
Governance, encryption, anonymization, and compliance (GDPR, CCPA)

Security Architecture:
Identity management, container security, and zero trust architecture

Top Questions About AI in Cybersecurity

- **GenAI in Security Tools**: Common use cases include incident summarization, threat research chatbots, and behavior modeling for triage and investigation.
- **AI Agents**: Task-specific agents (e.g., phishing triage) automate discrete security functions with high accuracy through focused training and prompts.
- **Agentic Systems**: Emerging concept where multiple AI agents collaborate to handle complex workflows (e.g., full incident response), but still in early stages.
- **Chatbot Use**: Helpful for documentation and threat research, but underutilized by practitioners due to workflow disruption.
- **Caution on Hype**: Many capabilities are not yet broadly available or reliable; rigorous evaluation is needed before adoption.

Source: https://www.forrester.com/blogs/your-top-questions-on-generative-ai-ai-agents-and-agentic-systems-for-security-tools-answered/

AI Cybersecurity Risks & Threats

Prompt: I'm building a presentation on cybersecurity and AI for a technical audience. Provide 5 ways ChatGPT and AI can be used maliciously.

- Enhanced cyber reconnaissance
- Automated social engineering
- Supercharged phishing
- Deepfakes and disinformation
- Malware automation & mutation
- Adversarial machine learning and data poisoning

Investigate Adversarial Techniques

ATLAS Matrix

The ATLAS Matrix below shows the progression of tactics used in attacks as columns from left to right, with ML techniques belonging to each tactic below. & indicates an adaption from ATT&CK. Click on the blue links to learn more about each item, or search and view ATLAS tactics and techniques using the links at the top navigation bar. View the ATLAS matrix highlighted alongside ATT&CK Enterprise techniques on the ATLAS Navigator.



https://atlas.mitre.org/matrices/ATLAS

OWASP AI Projects

https://owaspai.org/

AI Exchange





> *Welcome to the go-to resource for broad AI security & privacy - over 200 pages of practical advice and references on protecting AI and data-centric systems from threats. This content serves as key bookmark for practitioners, and is contributing actively and substantially to international standards such as ISO/IEC and the AI Act through official standard partnerships. Through broad collaboration with key institutes and SDOs, the Exchange represents the consensus on AI security and privacy.*
> *See the overview of AI projects at OWASP.*

Ways to start

- If you want to **protect your AI system**, start with risk analysis which will guide you through a number of questions, resulting in the attacks that apply. And when you click on those attacks you'll find the controls to select and implement.
- If you want to get an overview of the **attacks** from different angles, check the AI threat model or the AI security matrix. In case you know the attack you need to protect against, find it in the overview of your choice and click to get more information and how to protect against it.
- To understand how **controls** link to the attacks, check the controls overview or the periodic table.
- If you want to **test** the security of AI systems with tools, go to the testing page.
- To learn about **privacy** of AI systems, check the privacy section.
- Looking for more information, or training material: see the references.

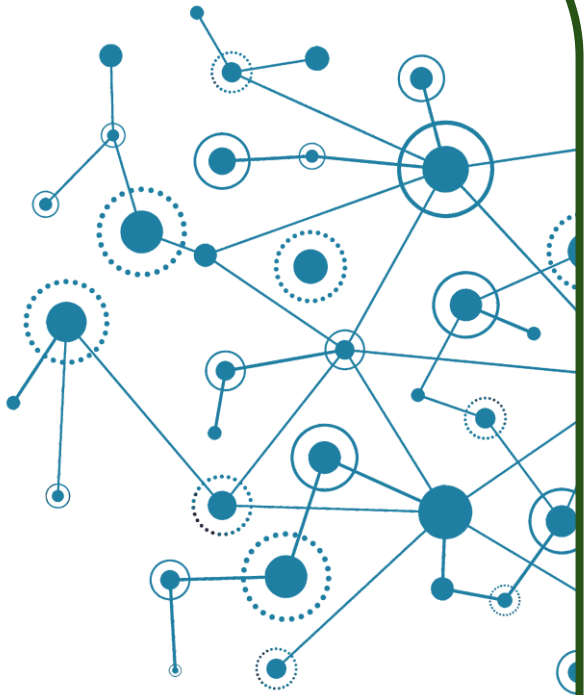
OWASP AI Projects

https://genai.owasp.org/



For more, see:

Beyond the Firewall: Evolving Cyber Skills for the Age of AI and Automation

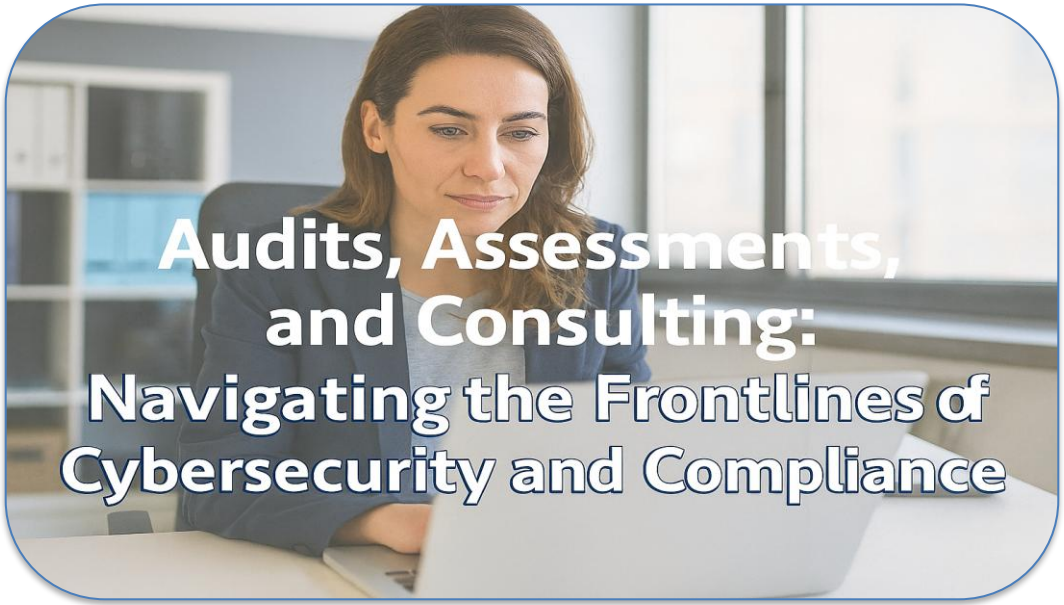


Ron Woerner, CISSP, CISM

vCISO, Consultant, and Educator
Cyber AAA, LLC
https://www.linkedin.com/in/ronwoerner/

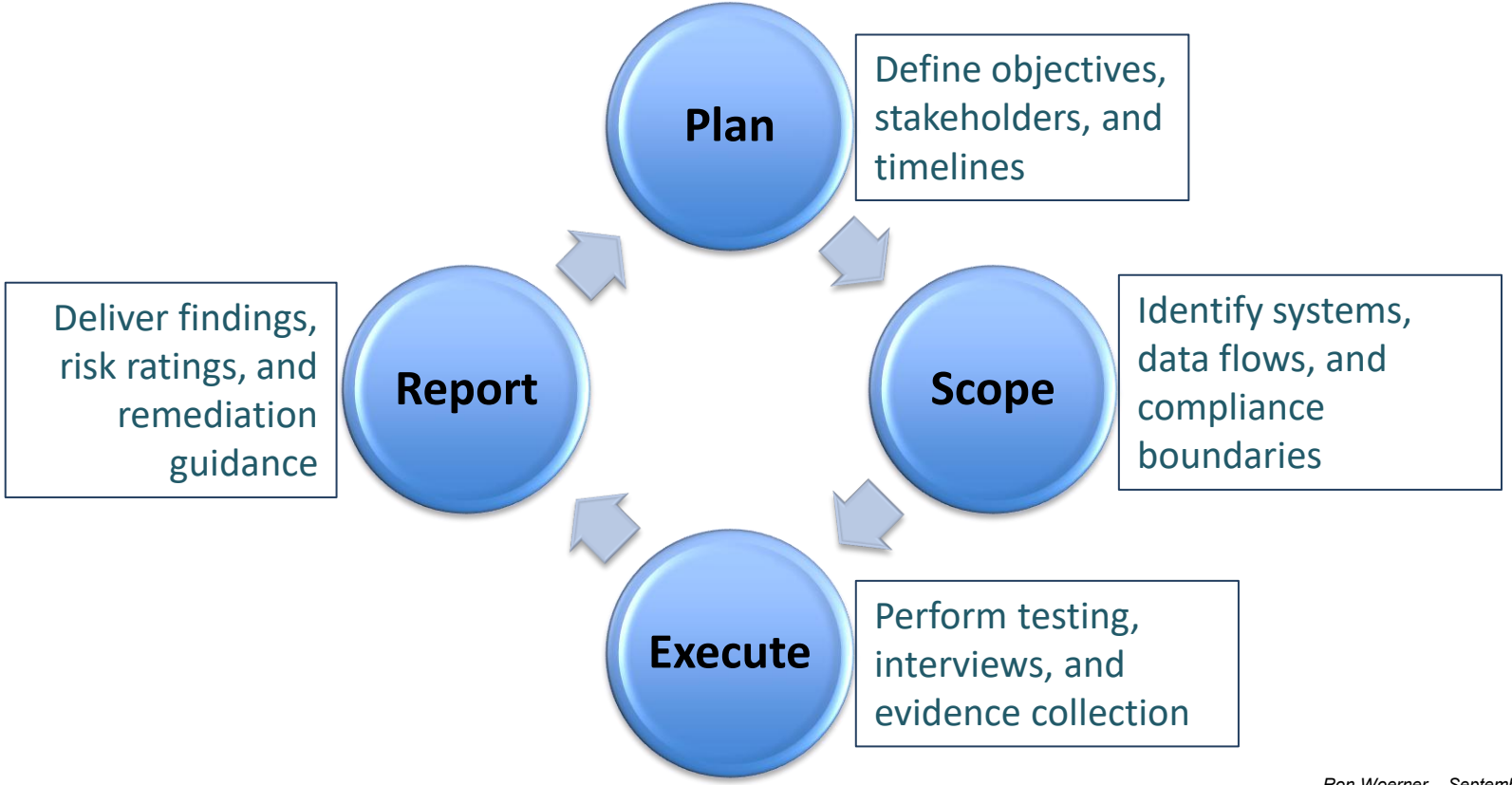
Slides are available at: https://github.com/hackerron/AI-Cybersecurity/blob/main/RWoerner%20-%20Evolving%20Cyber%20Skills%20-%20Sept2025.pdf

LIFE OF AN IT AUDITOR



Ron W

Audit & Assessment Lifecycle



Maturity Assessment & Growth Lifecycle

Assessing and analyzing capabilities to establish actionable improvements



What's the Difference Betweek Audit & Cybersecurity?

Make sure we're following the rules





Eugene Spafford's first principal of security administration:

If you have responsibility for security, but have no authority to set rules or punish violators, your role is to take the blame when something goes wrong.*

* Garfinkle & Spafford, Practical Unix & Internet Security, O'Reilly & Associates, Inc, 1996, p.39.



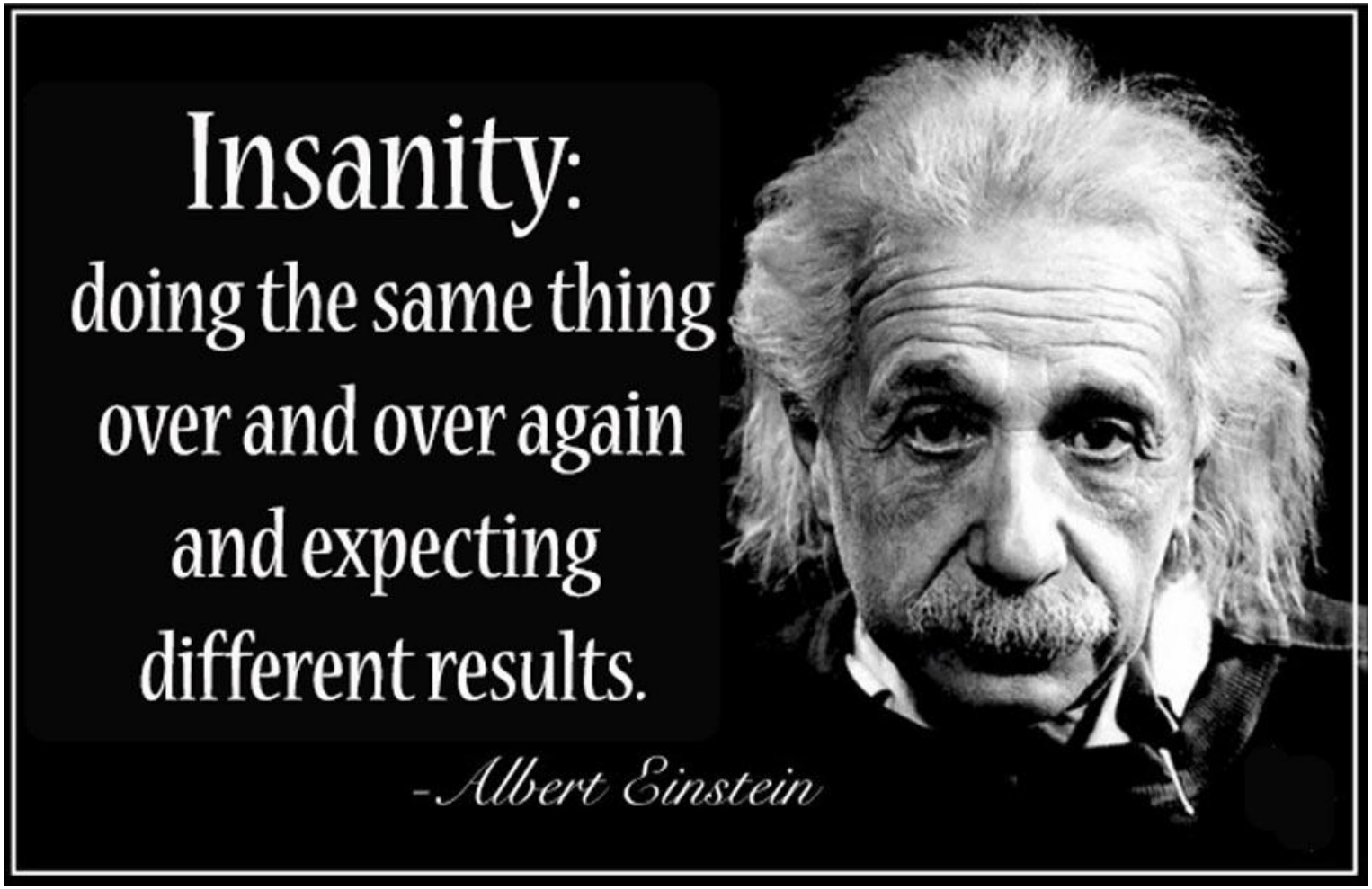
Talking over people's heads

"I have a couple employees who specialize in payment fraud who are wanting to get more involved with SecOps, which I'm finding communication avenues to be a challenging issue to overcome. When I explain basics, I have a habit of looking at basics as basic, and lose the fact that my basic is complicated for others."

Sucking at Cybersecurity / IT Audit

- Groundhog Day
- Influence / Communications
- Wrong Focus
- NO-it-alls
- Stress




Insanity:
doing the same thing
over and over again
and expecting
different results.
-Albert Einstein

NOT Sucking at Cybersecurity / IT Audit

- Start with “Why?”
- Do your homework
- ABC = Always Be Curious
- CYA = Challenge Your Assumptions
- Know Your Audience
- Talk Business Talk
- It’s All About Risk
  and risk is about economics



You can’t
(and shouldn’t try to) fix everything.

- Prioritizing risks vs costs
- Look for treasures
- Power of the pen

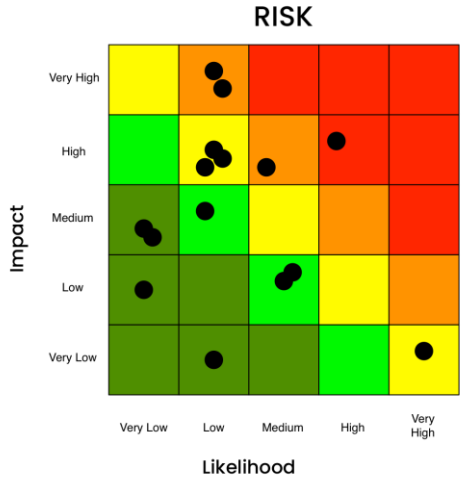
Who Owns the Headache?



Ron Woerner – September2025

Balancing Risk

- Qualitative
  - Low, Medium, High
  - Subjective



- Quantitative
  - Frequency of occurrence
  - Loss event probability
  - Impact costs ($, time, resources)



Homework

Cambridge Ideas - Professor Risk

https://youtu.be/a1PtQ67urG4?si=QdKHr-jnORqebQrF



Working together



Power of Observation



Next Steps / “Apply” Slide – Summary

Immediate (the next week):

- Review 2-3 resources from this presentation
- Investigate and experiment with AI
- Set a calendar reminder for 1 month…

Long-term (the next 1-2 months):

- Review the deck and experiment with 2-3 new resources
- Share with others
- Lead with curiosity, defend with wisdom





Thank You!

For More Information:

ronw@cyber-aaa.com

https://www.linkedin.com/in/ronwoerner/

https://linktr.ee/cyberron



MANIFEST YOUR INNER CYBER SUPERHERO!